

Beyond the Model Card

Engineering Trust into AI Systems
with AI/ML-BOM and CycloneDX

Matt Rutkowski

IBM Research, IBM Granite Model Enablement
OWASP CycloneDX Core Team
Chair, OWASP CycloneDX AI/ML Workgroup
Chair, LF AI & Data, Security & Compliance Comm.



Session Abstract

Model cards tell a story about an AI model, but trust is relative — it's judged against the system or application a model is embedded in, and the use case it's asked to serve. As the EU AI Act and Cyber Resilience Act push general-purpose AI providers from voluntary disclosure toward mandatory, auditable technical documentation, the industry needs a structured, machine-readable answer — not another PDF.

This talk draws on my work ensuring IBM's Granite models run across open and partner frameworks and apps — including local, agentic deployments — and on chairing the OWASP CycloneDX AI/ML Working Group, to show how CycloneDX AI/ML-BOMs can turn the concept of "model cards" into verifiable, regulation-mapped data. The goal: assess risk, confirm that the correct model — benchmarked and deployed for the task it's designed for — is actually in use, and verify regulatory and corporate policy compliance



Session topics

Why a “model card” isn’t enough

- *Research/Academic, Developer/Community and Corporate views*

A look at the current AI regulatory landscape

- *NIST, ENISA and the EU AI Act & CRA requirements for auditable technical documentation*

Review OWASP Cyclone AI/ML-BOM standardization efforts

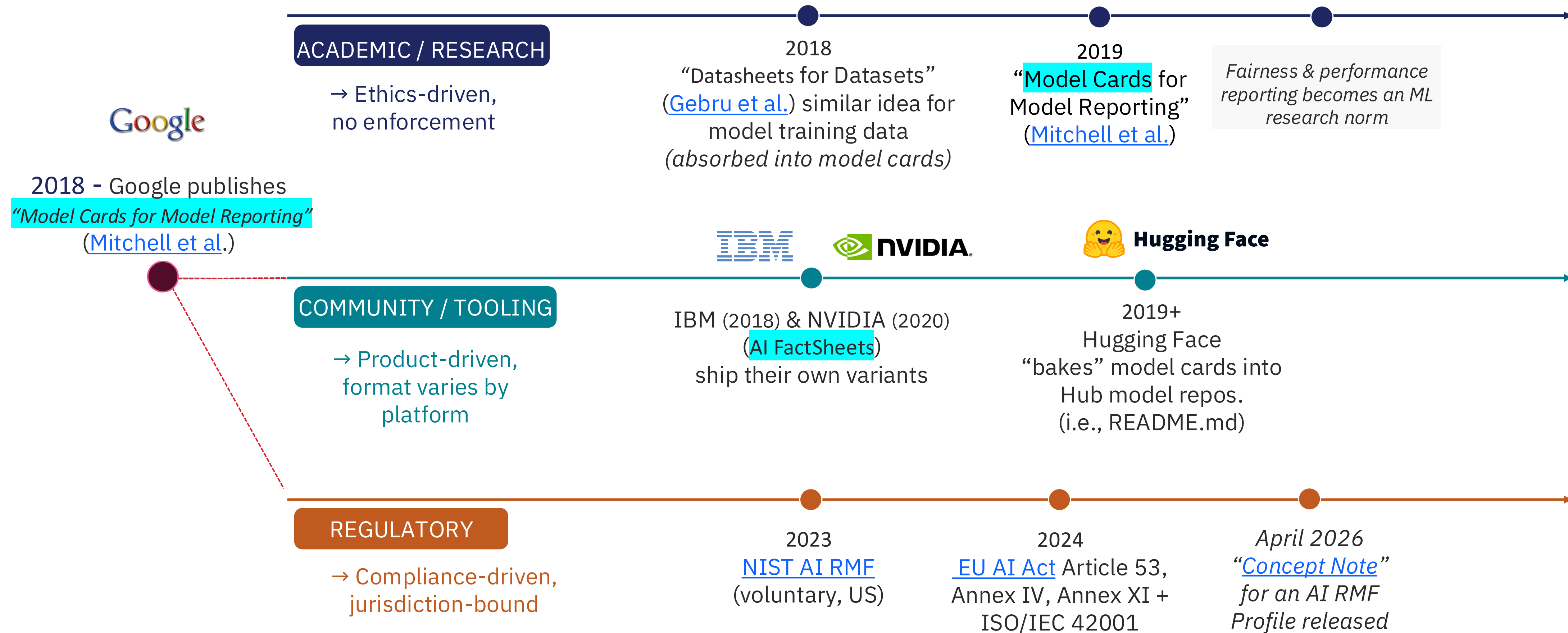
- *Review the goals of the first-of-a-kind “[OWASP Authoritative Guide to AI/ML-BOM](#)”
— with focus on EU CRA and EU AI Act requirements*

Beyond the model card with CycloneDX 2.0

- *Architecture, parties, risks, taxonomy and perspectives*

A History of the Model Card: Three Lineages, No Convergence

Academic, community, and regulatory efforts on AI documentation evolved independently
— and still haven't merged



What does a “Model Card” look like today?

Companies and organization have been publishing their own “model cards”
— *with no common structure, format, or regulatory grounding*



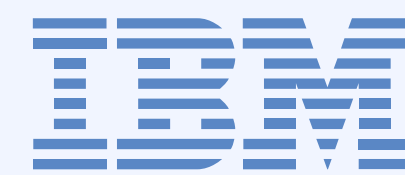
Format: Transparency Notes (web/PDF)
Responsible AI docs are published as web pages or PDFs
— structure differs by product line



Format: Service docs & blog posts
Model docs. are folded into service pages and blog posts
— built for onboarding, not compliance



Format: Repository README files
Community-authored, free-text “model cards” per repo.
— no enforced schema or required fields



Format: Web pages, blog posts & PDFs
Granite model cards are published as web pages and PDFs
— depth and fields vary by product team



Format: Model Cards (web/PDF)
Structured web pages
— more standardized than most, but still Google-specific

*No shared schema, no machine-readable structure, and
no deterministic mapping to regulatory requirements*

Cybersecurity Regulatory Landscape – EU and US

Cybersecurity regulations and standards are principally being driven by ENISA and NIST



European Union Agency for Cybersecurity ([ENISA](#))

- *focuses on policy, risk management, and cooperation among EU member states*
 - [EU Cyber Resilience Act \(CRA\)](#) - Generalized Cybersecurity Requirements
 - [EU Artificial Intelligence Act](#) - AI Specific requirements for the EU CRA
 - **Compliance required** for AI System/Model providers, deployers, distributors, product manufacturers, importers
 - *including specific information/templates for AI model cards*
 - *i.e., primarily Article 54, and Annex XI*

NIST



National Institute of Standards and Technology ([NIST](#))

- [NIST Cybersecurity \(CSF\) 2.0 Framework](#) - *focus on governance, supply chain risk management, and measurement of cybersecurity outcomes while **aligning more closely with international standards***
- Cybersecurity Infrastructure Security Agency ([CISA](#)) – *Acts as the central federal authority for cybersecurity, driving agency compliance through Binding Operational Directives (BODs) for government agencies*
 - *Operates under the [Cybersecurity Information Sharing Act of 2015](#) which was [extended by Congress through Sept. 2026](#)*

The EU AI Act's enforcement continues incrementally



Key implementation milestones:

Recently reshaped by a mid-2026 amendment

- **2 Feb 2025:** Prohibitions on unacceptable-risk AI systems and AI literacy obligations became applicable.
- **2 Aug 2025:** General-purpose AI (GPAI) model rules, governance, and penalties became applicable.
- **2 Aug 2026:** Article 50 transparency obligations apply; GPAI rules and Art. 5 prohibitions remain in force. Digital Omnibus on AI enters into force.
- **2 Dec 2026:** Art. 50(2) watermarking applies to legacy systems; new prohibition on AI-generated non-consensual imagery/CSAM.
- **2 Dec 2027:** *(delayed)* High-risk obligations apply to Annex III (stand-alone) AI systems. *(was 2 Aug 2026)*
- **2 Aug 2028:** *(delayed)* High-risk obligations apply to Annex I (embedded) AI systems. *(was 2 Aug 2027)*

Delays are conditional backstops.

The Commission can confirm standards/guidance earlier, shortening the transition.

Organizations must plan for compliance with these deadlines, as the law applies to any AI systems used in the EU, *regardless of where the provider is located*

Other countries may follow EU path /guidance...

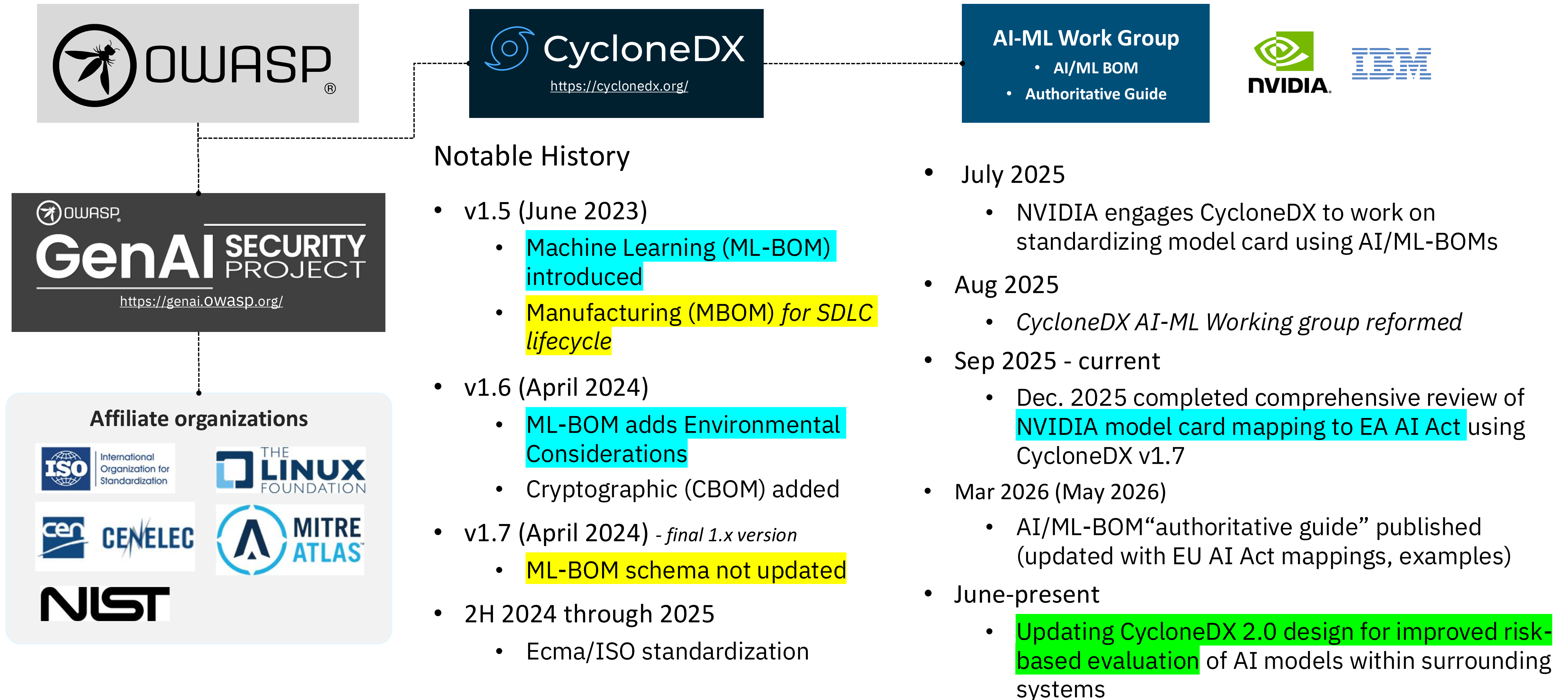


“Brussels Effect” may lead to similar convergence
— However, other jurisdictions are choosing “lighter-touch” paths

Countries/ Jurisdictions	Regulatory Posture	Detail
European Union	Binding, comprehensive	Only fully binding, risk-based AI law; the global compliance benchmark.
Brazil, Peru	EU-modeled (in progress)	Risk-based bills closely follow the EU structure; Brazil’s PL 2338/2023 still pending in Congress.
South Korea, Vietnam	Binding, independently designed	Comprehensive AI laws now in force, but not built on the EU template.
Japan, UK, Canada, Australia, Singapore	Principle-based / light-touch	Voluntary frameworks, sector regulators, or non-binding promotion acts; Canada’s AIDA bill lapsed in 2025.
India	Guidelines only, no binding law	2025 AI Governance Guidelines + 2026 IT Rules amendment (synthetic content); private AIACT.IN bill is not government-backed

- **USA:** No federal AI law — March 2026 White House framework push Congress toward one. States (CA’s TFAIA, CO’s AI Act) are already enforcing binding rules.
- **China:** No single AI Act — binding, by-sector rules (generative AI, deep synthesis, algorithms) enforced via CAC filing, ~800 services registered as of Feb. 2026.
- **Private Sector:** Frontier labs’ voluntary safety commitments & the Linux Foundation’s Agentic AI Foundation (AAIF) ~150 members standardizing agent protocols like MCP — are filling gaps ahead of binding law.

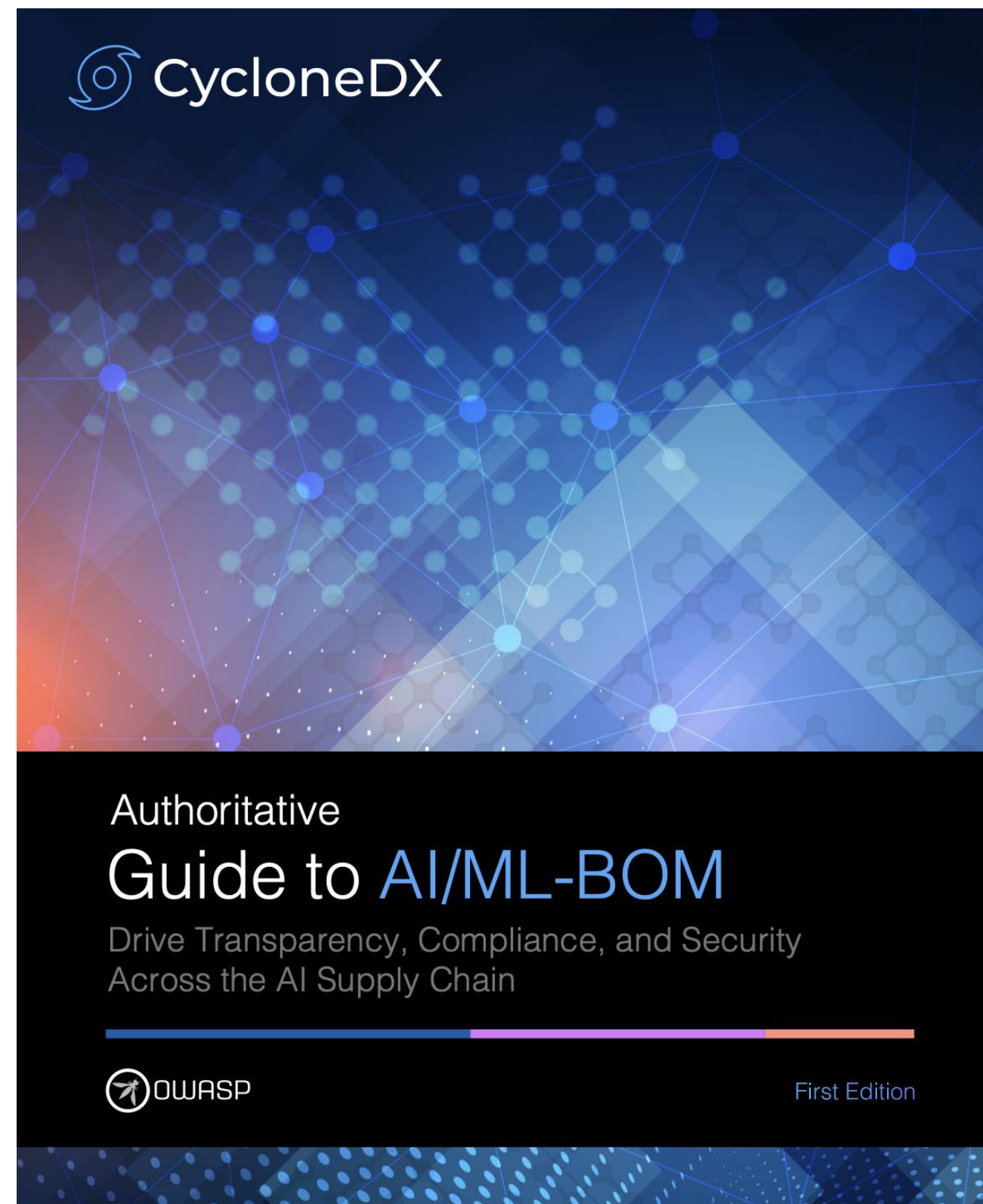
OWASP CycloneDX AI/ML-BOM Standardization – A short history



AI/ML-BOM Authoritative Guide is designed to meet EU AI Act Requirements

The guide provides prescriptions for creating CycloneDX Model Cards **specifically designed for the EU AI Act:**

OWASP Released March 2026



Model identity, design and configuration

- Design Goals/Tasks - e.g., classification, regression, clustering, generation, etc.
- Model Architecture - Neural Network type, implementation class
- Dataset disclosure - Full description of datasets used for training/evaluation
- Model Inputs & Outputs - Data format specifications (incl. chat template, prompts)
- Configuration Parameters & Hyperparameters – defaults or per-instance

Design & Development Considerations

- Users & Use Cases - Intended users (roles) and application scenarios
- Learning Approach – e.g., reinforcement-learning, semi-supervised, self-supervised
- Known Technical Limitations – e.g., (hallucination, reasoning deficiencies, bias)
- Performance Tradeoffs - Balance decisions (accuracy vs. speed, complexity vs. resources, precision vs. recall)
- Ethical Considerations - Known ethical risks with mitigation strategies
- Fairness Assessments - Impact on at-risk groups, potential harms and benefits
- Environmental Considerations – Training/Inference costs with CO2 cost equivalents/offsets

Quantitative Analysis

- Performance Metrics - Standardized measurements (accuracy, precision, recall) against...
- Benchmarks – Describe test datasets and results (MMLU, GSM8K, HumanEval, GLUE, etc.)

*Moving Beyond the Model Card
using
the current CycloneDX 1.7 standard*

Ideally, an AI/ML-BOM should account for the entire Model Development Lifecycle (MDLC)



Design Phase

Specifications & Architecture

- Use Cases, User Roles & Risk Boundaries
- Define user roles, interaction models and success criteria (metrics)
 - Persona workflows, operational constraints and *threat modeling*
- Architecture Decisions
- Task types: classification, regression, generation, embedding, etc.
 - Modalities, activation layers, attention mechanisms, Mixture-of-Experts (MoE), etc.
 - Language, tool and reasoning capabilities
- Data & Input / Output Specifications
- Strict input/output schema specifications (supported formats)
 - Prompt Templates, feature schemas
 - baseline hyperparameters



Development Phase

Data, Training & Benchmarking

- Data Selection & Preparation
- Curated training and fine-tuning datasets
 - Provenance, licensing and PII
- Training
- Pretraining, fine-tuning, and alignment runs
- Benchmarking
- Standardized accuracy and latency tests; measure against success criteria
- Alignment Gates
- Mid-training “checkpoints” to *assure model alignment*
- Robustness
- Stress testing under adversarial conditions (e.g., *prompt injections*, *jailbreaks*, etc.)



Testing & Evaluation

Validation & Benchmarks

- Fairness Audit
- Demographic bias assessments across subgroups, against design thresholds
- Benchmarking
- Standardized accuracy and latency tests against baselines and success criteria
- Robustness & Safety
- Stress testing under adversarial conditions, *red-teaming*
- Use-Case & System Testing
- Scenario-based and human-in-the-loop evaluation of target persona workflows
 - End-to-end testing with tools, RAG, etc.
- Validation Gates
- Quality threshold checks with documented results
 - Formal release sign-off



Trusted Delivery

Provenance & Distribution

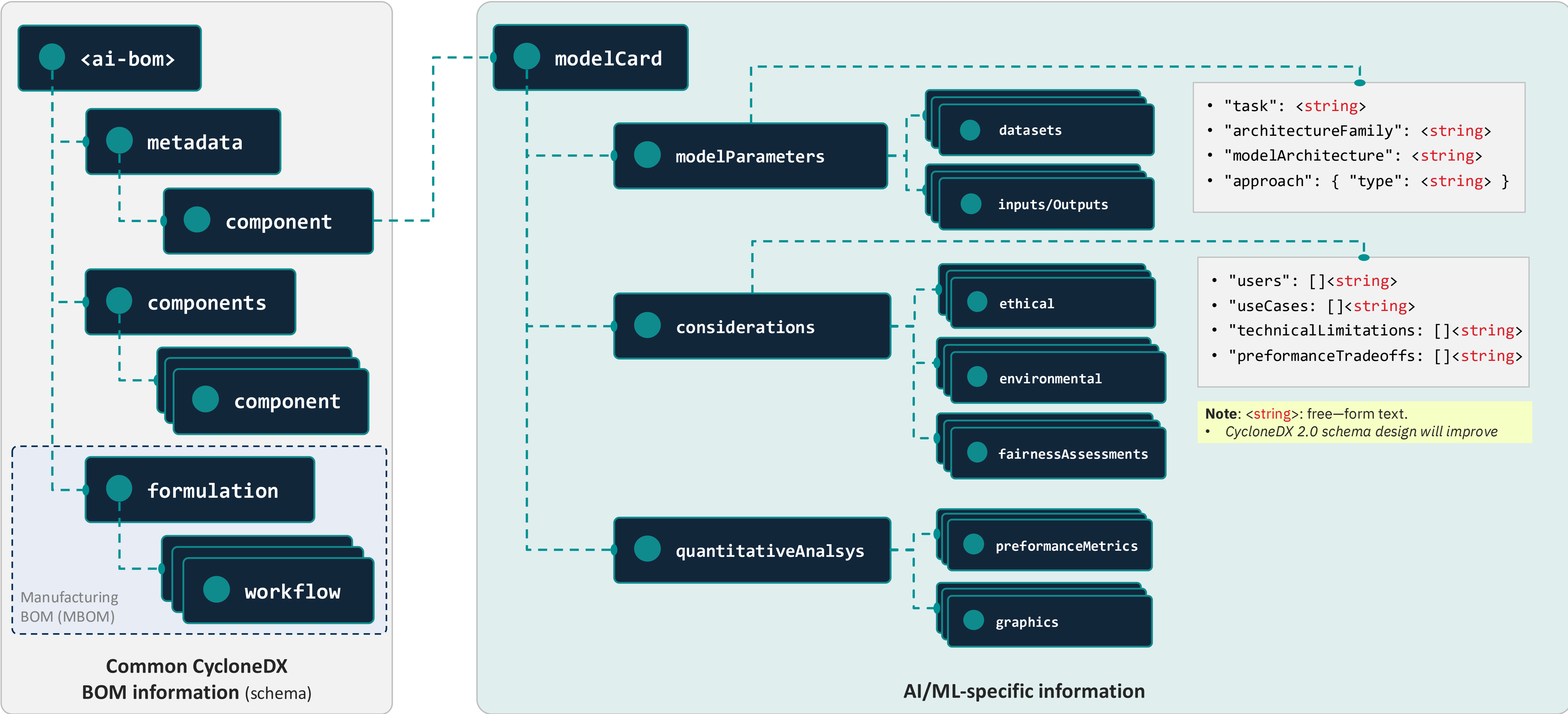
- Trusted Model Registry
- Secure repository with access controls, versioning, and rollback/deprecation
- Clear Licensing
- Explicit usage and distribution rights covering weights, data, and dependencies
- Artifact Signing
- Verifiable cryptographic signatures for integrity
- Model Documentation & Known Limitations
- Lineage: Complete dataset and model provenance and code dependencies
 - Summarize dataset/data selection and learning approach, intended use, and evaluation results
 - Known technical limitations, ethical considerations

DESIGN & BUILD PHASES

VERIFICATION & GOVERNANCE PHASES

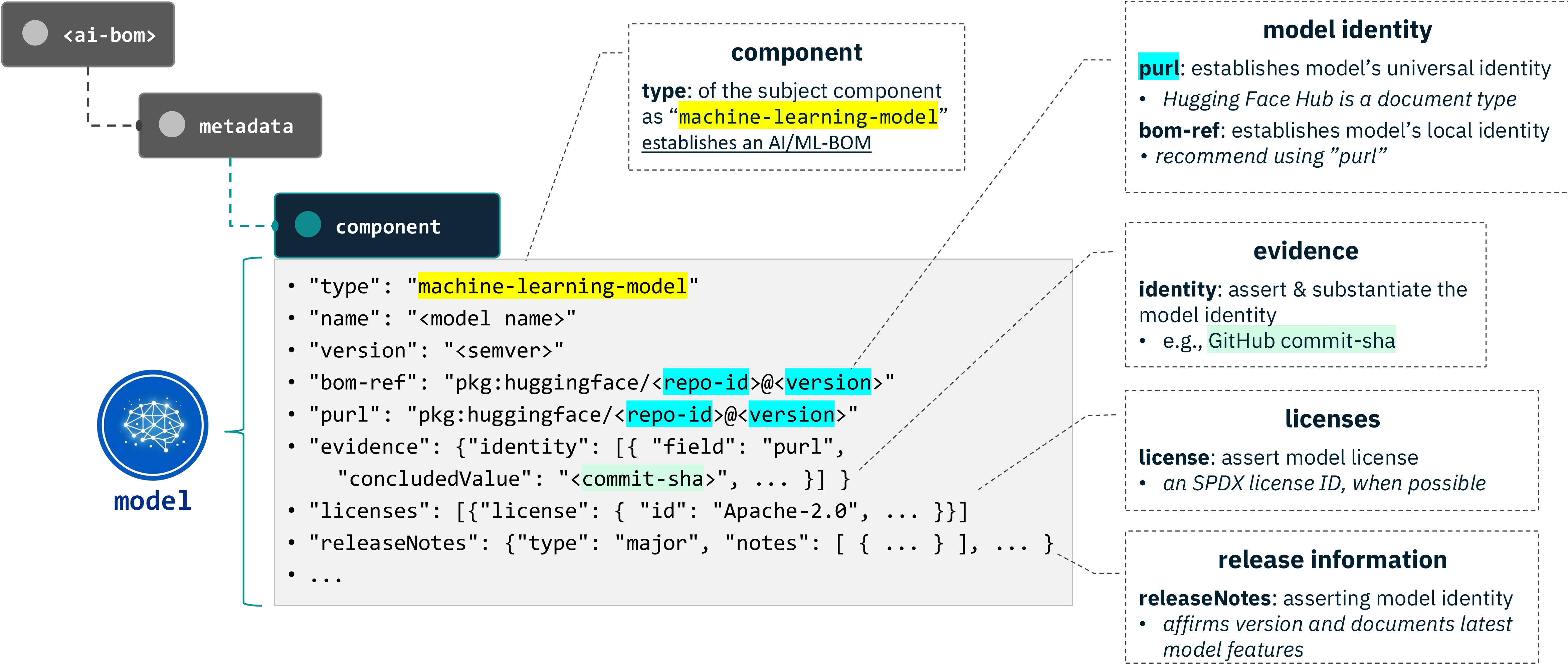
Anatomy of a CycloneDX AI/ML-BOM: Overview

Normalizing model, dataset and development information using CycloneDX v1.7



Using CycloneDX to describe an AI Model: The Basic “BOM stuff”

Establishing an AI/ML-BOM with a model “component” using CycloneDX schema



Using CycloneDX to describe a training dataset

A 2.0 “data” component, referenced from the model’s training datasets

● component · type: data

```
"components": [
{
  "type": "data",
  "name": "GneissWeb",
  "bom-ref": "pkg:huggingface/ibm-granite/GneissWeb",
  "purl": "pkg:huggingface/ibm-granite/GneissWeb",
  "description": "IBM-curated large-scale dataset for LLM pre-training, ...",
  "publisher": "IBM",
  "externalReferences": [
    {
      "type": "distribution",
      "url": "https://huggingface.co/datasets/ibm-granite/GneissWeb"
    },
    { "type": "documentation", "url": "https://arxiv.org/abs/2502.14907" }
  ],
  "properties": [
    { "name": "cdx:ai-ml:dataset:category", "value": "web" },
    { "name": "cdx:ai-ml:dataset:stage", "value": "pre-training" },
    { "name": "ibm:ai-ml:dataset:size", "value": "29492.2 GB" },
    { "name": "ibm:ai-ml:dataset:languages", "value": "en" },
    ...
  ],
  "licenses": [{ "license": { "id": "Apache-2.0" } } ]
},
...
]
```



● component · model

```
{
  "type": "machine-learning-model",
  "name": "<model name>",
  "bom-ref": "pkg:huggingface/<repo-id>@<version>",
  "modelCard": {
    "modelParameters": {
      "datasets": [
        { "ref": "pkg:huggingface/ibm-granite/GneissWeb",
          ...
        }
      ]
    }
  }
}
```

the link to the model
modelProperties.training.datasets[]
holds the data component’s bom-ref
or a BOM-Link when the dataset is declared in another BOM; training.formula can reference the training stages

component
type: "data" declares a dataset

dataset identity
bom-ref: local identity, the target the model references
purl: universal identity (Hugging Face)

references
externalReferences: distribution & documentation
e.g., the arXiv paper describing the data

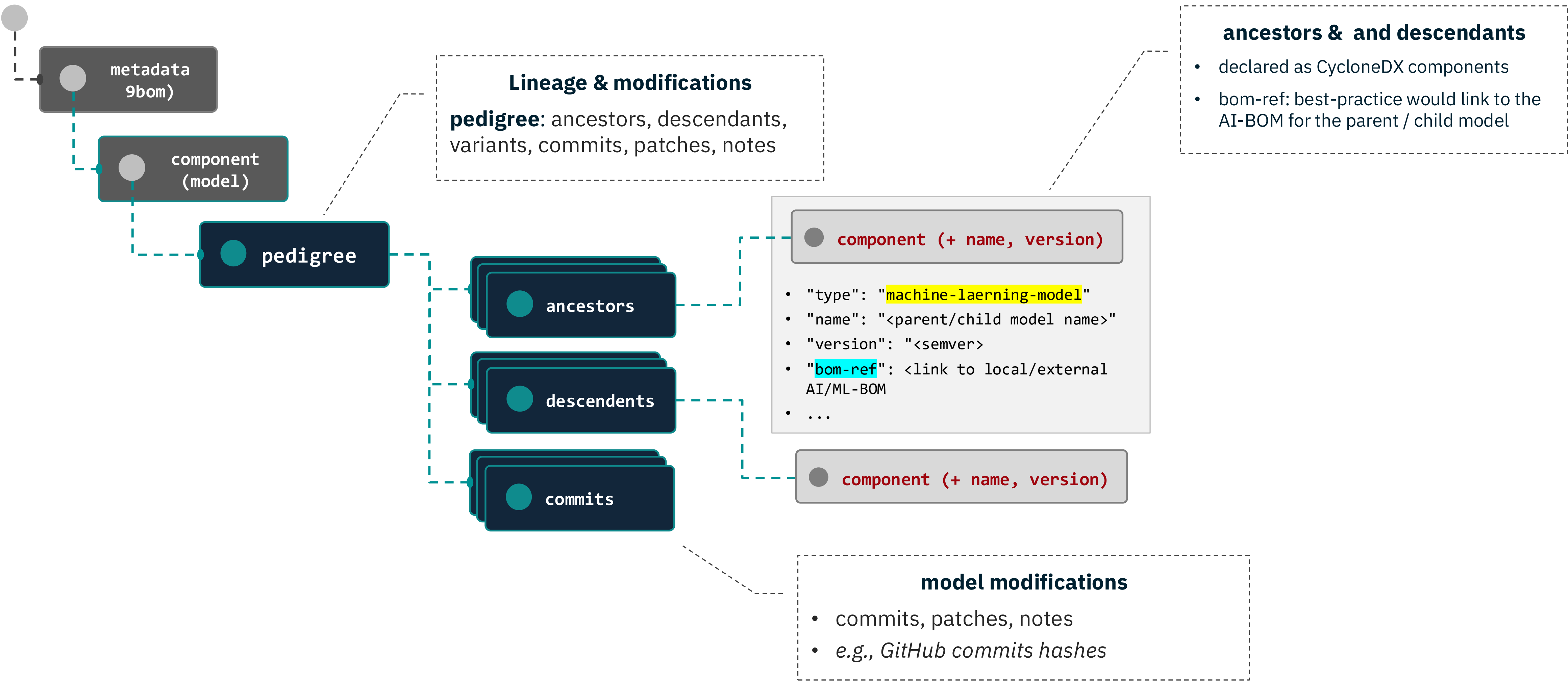
properties
cdx:ai-ml:dataset:*: taxonomy (category, stage)
ibm:*: vendor names for the rest

licenses
license.id: SPDX ID, e.g., Apache-2.0

Data components (i.e., dataset declarations) should live in the top-level components[] array

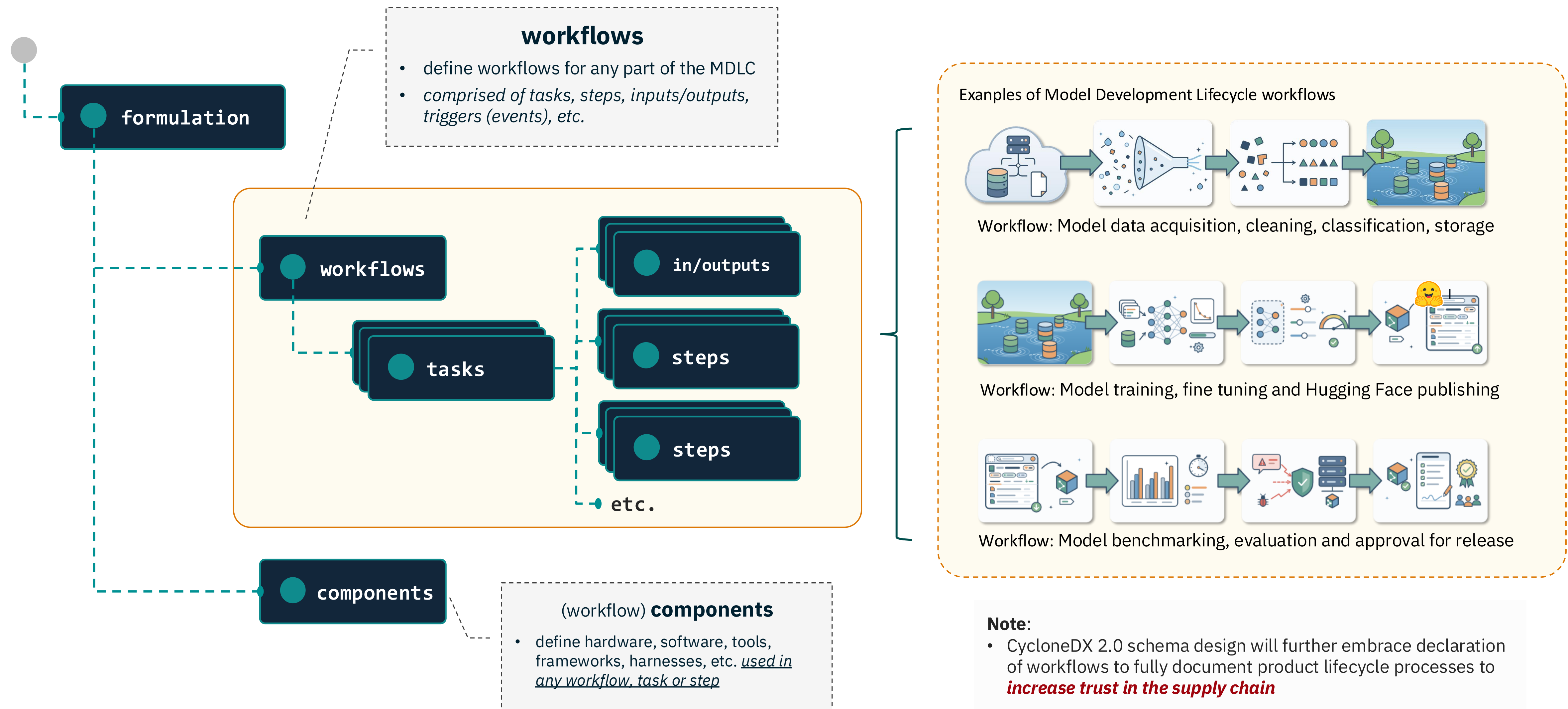
Asserting model provenance & pedigree

The same CycloneDX methodology & common schema objects are utilized



Document data acquisition, preparation, training/tuning & benchmarking

For any BOM, repeatable processes are encoded using CycloneDX **Manufacturing (MBOM)** schema



Moving Beyond the Model Card using CycloneDX 2.0 modular schema

- *In-depth model architecture descriptions*
- *Explicit use cases, roles, parties*
 - *representation of (legal) parties*
- *Risk-based, model design considerations*
- *Perspectives (model card design, view)*
- *Using the AI-ML CycloneDX Property Taxonomy*

Describing model architecture: from 2 strings to a 3-tier model

What a model is built from, how it is built, and how it runs

CycloneDX 1.7

```
"modelParameters": {  
  "architectureFamily": "Hybrid Mamba/Transformer",  
  "modelArchitecture": "Decoder-only MoE",  
  ...  
}
```

- Two free-text strings**
- **No controlled vocabulary:** “CNN”, “ConvNet”, “convolutional” all differ
 - Structure, mechanisms and runtime behavior collapse into one value
 - Hybrid & MoE models don’t fit a single “family”
 - Cannot be validated, queried or compared across BOMs



modelArchitecture

+ name, description,
externalReferences, properties

TIER 1 family

What is the model fundamentally built from?

one value · 20 predefined + custom

transformer cnn mamba diffusion hybrid ...

TIER 2 features

Which structural mechanisms does it use?

array · 26 predefined + custom

decoder-only mixture-of-experts u-net ...

TIER 3 topology

How are parameters activated at runtime?

one value · 7 predefined + custom

dense sparse dynamic early-exit ...

CycloneDX 2.0

```
"architecture": {  
  "name": "Granite 4.0 Hybrid",  
  "family": "hybrid",  
  "features": [  
    "decoder-only",  
    "mixture-of-experts",  
    "state-space-model"  
  ],  
  "topology": "sparse",  
  "externalReferences": [...]  
}
```

- Structured & machine-readable**
- Enumerated values can be validated, queried and compared across models and BOMs
 - Describes hybrid, MoE & multimodal designs precisely
 - Custom {name, description} objects keep every tier extensible

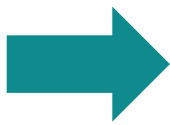
Use cases & roles: from free-text lists to accountable parties

Who acts, in which legally defined role, doing what, traced to the system

CycloneDX 1.7

```
"modelCard": {
  "considerations": {
    "users": ["Loan officers"],
    "useCases": ["Credit scoring"],
    ...
  }
}
```

- Two lists of strings
- **Users are labels, not identifiable parties:** no legal name, jurisdiction or identifiers
 - No roles, so obligations cannot be assigned (e.g., deployer, controller ...)
 - Use cases have no actors, steps, conditions or exceptions
 - Nothing links them to components, flows or requirements



parties, roles & useCases

party, blueprint & usecase
2.0 schemas

WHO party
An organization, person, system (e.g., AI agent) or persona
roles (66 predefined + custom) · legalName · jurisdiction · identifiers (LEI, DUNS ...)

IN CONTEXT actor
Binds a party to the modeled system in a blueprint
permissions scoped to the system · trust zone

WHAT useCase
A goal-driven interaction between actors and the system
pre/postconditions · mainFlow steps (each names its actor) · alternativeFlows · exceptions

TRACED TO assets · flows · requirements
Blueprints link use cases to assets & flows; components assert their relationship
implements · participates-in · supports · validates · inhibits ...

CycloneDX 2.0

```
"parties": [{
  "bom-ref": "party-bank",
  "organization": {
    "legalName": "Example Bank S.p.A.",
    "jurisdiction": "IT"
  },
  "roles": [
    { "role": "data-controller" },
    {
      "name": "deployer",
      "description": "EU AI Act, Art. 3(4)"
    }
  ]
}],
"useCases": [{
  "bom-ref": "uc-credit",
  "name": "Assess creditworthiness",
  "actors": ["actor-bank", "actor-applicant"],
  "mainFlow": [{ "number": 1, "actor": "actor-bank", ... }],
  "exceptions": [...]
}]
```

- Regulation-ready & traceable
- Legal names, identifiers & roles mirror regulatory terms (EU AI Act, GDPR)
 - Every step names who acts; use cases link to the assets and flows they exercise

Risk-based design (1/2): attaching ethical risks to the model

Design-time considerations become acknowledged risks attached to the model

CycloneDX 1.7

```
"ethicalConsiderations": [
  {
    "name": "Algorithmic and cultural bias. Trained
on web-scale data in many languages,
the model may reflect societal
stereotypes ...",
    "mitigationStrategy": "Detect and reduce
implicit bias with CoT
prompting ..."
  },
  {
    "name": "Misinformation or hallucinations. The
model can fabricate false information
...",
    "mitigationStrategy": "Use RAG to ground
responses ..."
  }
]
```

- Everything is a name string
- One string fuses risk, cause and context
 - No identity, domain, severity or harm category
 - Benefits are not stated at all
 - Nothing links the risk to the model component



risks

top-level BOM object, \$ref to cyclonedx-risk-2.0 #/\$defs/risks

CONTAINER risks
Top-level BOM list holding the risk information as referenceable objects
risks[] · assessments[]

DECLARE bom-ref · name · statement
Required on every risk; statement reads source → event → impact
bom-ref makes the risk referenceable from assessments and responses

ATTACH affects
The model's bom-ref, plus any party for a group at risk
e.g., a persona party (replaces 1.7 groupAtRisk) · bom-ref or bom-link

QUALIFY domains · impacts
Domains: ethical, fairness, societal ...; each impact is a harm or a benefit
each impact graded: negligible → catastrophic · categories: discrimination, societal ...

CycloneDX 2.0

```
"components": [{
  "type": "machine-learning-model",
  "name": "Aster-7B-Instruct",
  "bom-ref": "model-aster-7b"
}]

affects[ ] holds the model's bom-ref
bold keys = required · risk-hallucination: same shape

"risks": {
  "risks": [{
    "bom-ref": "risk-bias",
    "name": "Algorithmic and cultural bias",
    "statement": "Skewed web-scale corpus → stereotyped outputs
→ representational harm",
    "domains": [{ "type": "ethical" }, { "type": "fairness" }],
    "affects": ["model-aster-7b"],
    "inherentRisk": {
      "impacts": [
        {
          "polarity": "harm",
          "level": "major",
          "categories": ["discrimination"]
        },
        {
          "polarity": "benefit",
          "level": "moderate",
          "categories": ["societal"]
        }
      ]
    }
  }]
}
```

Risk-based design (2/2): harms & benefits become graded impacts

Design-time harms & benefits, each graded and paired with a known mitigation



Perspectives: the model card becomes a view, not a fixed object

A perspective maps AI-BOM data into model-card terms (in development)

2.0 AI-BOM

2.0 perspective

a lens on 2.0 AI-BOM data: RFC 9535
JSONPath → the audience's own terms

the view

```
"components": [{
  "type": "machine-learning-model",
  "bom-ref": "model-aster-7b",
  "name": "Aster-7B-Instruct",
  "modelProperties": {
    "tasks": ["text-generation"],
    "limitations": ["May fabricate facts"]
  }
},
{
  "type": "use-case",
  "bom-ref": "uc-chat",
  "name": "Chat assistant for developers"
},
{
  "type": "risk",
  "bom-ref": "risk-bias",
  "name": "Algorithmic and cultural bias",
  "statement": "The model may reflect cultural biases present in its training data, producing outputs that systematically disadvantage certain groups.",
  "domains": [{ "type": "ethical" }],
  "affects": ["model-aster-7b"]
}
]
```

Data lives where it belongs

- Model facts in modelProperties
- Use cases & risks are shared, referenced objects

```
"perspectives": [{
  "bom-ref": "perspective-model-card",
  "name": "Model Card",
  "domains": ["machine-learning", "transparency", "ethics"],
  "mappings": [
    {
      "expression": "$..[?(@.type=='machine-learning-model')].modelProperties.tasks",
      "nativeName": "Supported Tasks",
      "relevance": "required",
      "weight": 0.9
    },
    {
      "expression": "$.definitions.useCases[*]",
      "nativeName": "Intended Use",
      "relevance": "required",
      "weight": 0.9
    },
    {
      "expression": "$..[?(@.type=='machine-learning-model')].modelProperties.limitations",
      "nativeName": "Technical Limitations",
      "relevance": "required",
      "weight": 0.9
    },
    {
      "expression": "$.risks.risks[?(@.domains[?(@.type=='ethical')])]",
      "via": [{ "referrers": "$.risks.risks[*].affects[*]" }],
      "nativeName": "Ethical Considerations",
      "relevance": "required",
      "weight": 0.9
    }
  ]
},
...
]
```

via proposed traversal step · weights drive completeness scoring

MODEL CARD	Aster-7B-Instruct
Supported Tasks REQUIRED	text-generation <i>modelProperties.tasks</i>
Intended Use REQUIRED	Chat assistant for developers <i>use case uc-chat (every use case in the BOM; no model link yet)</i>
Technical Limitations REQUIRED	May fabricate facts <i>modelProperties.limitations</i>
Ethical Considerations REQUIRED	Algorithmic and cultural bias: may reflect training-data biases that disadvantage certain groups <i>risk risk-bias, found because it affects the model</i>

Canonical perspective

- Model card informed by EU AI Act requirements
- Same AI-BOM, other perspectives for other audiences

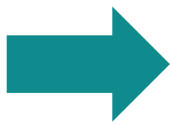
CycloneDX Property Taxonomy: an AI/ML vocabulary at the pace of AI

The CycloneDX schema stays a stable standard; the taxonomy grows any time

2.0 schema

```
"components": [{
  "type": "machine-learning-model",
  "name": "Aster-7B-Instruct",
  "modelProperties": {
    "tasks": ["text-generation"],
    "architecture": {
      "family": "transformer",
      "features": ["decoder-only"]
    },
    "parameterCount": 7000000000,
    "quantization": {
      "method": "gptq",
      "bits": 4
    },
    "properties": [...]
  }
}]
```

- Standardized Extension Mechanisms**
- properties[] is the schema's extension point for taxonomy names
 - Part of the Ecma / ISO standard



cdx:ai-ml taxonomy

2.0 SCHEMA

Ecma / ISO standard: stable, changes follow the ratification cycle

PROPERTY TAXONOMY

New names & values added any time, usable in any AI-BOM at once

MODEL model:modality · language

text · code · instruct · image · audio ... · ISO 639-1

MODEL model:parameter · hyperparameter

tune_method: sft · rlhf · lora · context_length · vocab_size

MODEL model:architecture · task · metric

new benchmarks: swe-bench · ttft · carbon-intensity ...

TOKENIZER tokenizer:hyperparameter

bos_token · eos_token · chat_template · vocab_size ...

DATASET dataset:stage · category · data:sources

pre-training · synthetic · web-crawl (EU AI Act Annex XI)

CycloneDX 2.0

a model component and its tokenizer component

```
{
  "type": "machine-learning-model",
  "name": "Aster-7B-Instruct",
  "properties": [
    { "name": "cdx:ai-ml:model:modality", "value": "instruct" },
    { "name": "cdx:ai-ml:model:language", "value": "en,de,fr,ja" },
    { "name": "cdx:ai-ml:model:parameter:tune_method", "value": "sft,rlhf" },
    { "name": "cdx:ai-ml:model:hyperparameter:context_length", "value": "32768" },
    { "name": "cdx:ai-ml:model:hyperparameter:undefined:rope_theta", "value": "500000" }
  ]
}
```

```
{
  "type": "library",
  "name": "aster-tokenizer",
  "properties": [
    { "name": "cdx:ai-ml:model:tokenizer", "value": "true" },
    { "name": "cdx:ai-ml:tokenizer:hyperparameter:vocab_size", "value": "128000" }
  ]
}
```

undefined:<NAME> declares a name not yet registered, with no schema change

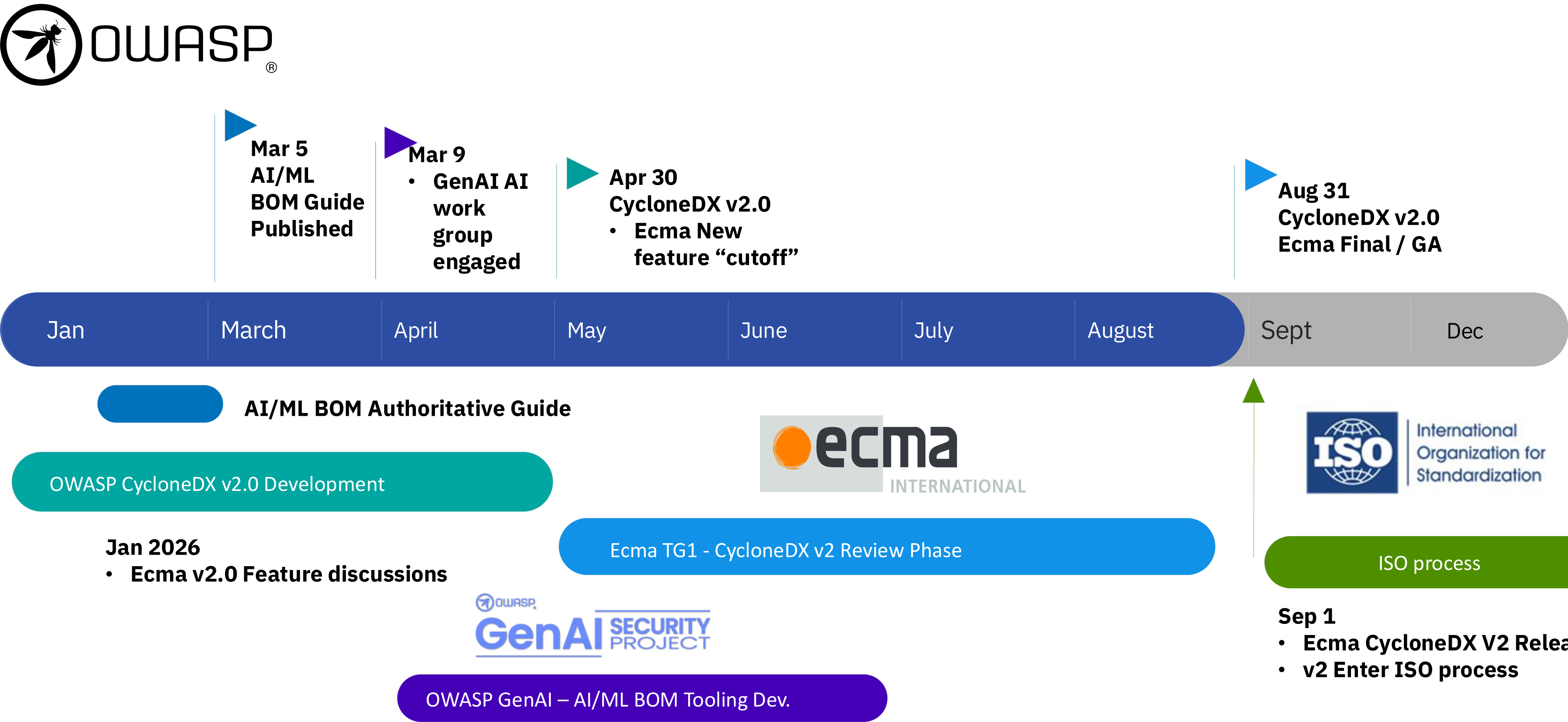
Repository: <https://github.com/CycloneDX/cyclonedx-property-taxonomy>
AI/ML Proposal: <https://github.com/CycloneDX/cyclonedx-property-taxonomy/pull/175>

Backup materials

- OWASP CycloneDX Timeline
- Graphics



OWASP CycloneDX AI/ML BOM Plans 2026 relative to AI/ML BOM



Backup: risk-centric object relationships in a 2.0 AI-BOM

How a machine-learning-model, its risks and the affected parties link together



bold key = required ◆ — contains (JSON nesting) -- ▶ references another object by bom-ref grey = optional customer scoring

Design Palette

